

4.3 Module Quiz

Date: 3/20/2026, 2:55:19 PM

Time Spent: 05:45

Score: 100%

Passing Score: 80%



A security team periodically feeds a set of known malicious and known benign emails into an AI-based phishing filter to see whether its decisions still match expectations.

The results are reviewed by experts, who document any errors and recommend updates.

Which practice does this activity BEST represent?

- ☐ Incident triage
- ☒ Human validation ✓ Correct
- ☐ Automated retraining
- ☐ Continuous deployment

Explanation

Human validation is the correct answer. Human validation occurs when experts deliberately test model outputs against known cases and judge whether the AI is behaving correctly. By feeding in known malicious and benign emails, reviewing outcomes, and documenting errors, the team is validating that the system's decisions still align with expectations.

Automated retraining is incorrect. Automated retraining focuses on using new data to update the model without necessarily involving people in checking whether specific outputs are correct. It does not require experts to compare model decisions against expected results in a structured, test-based way.

Continuous deployment is incorrect. Continuous deployment is about frequently pushing new versions of models or software into production. It does not describe the process of humans examining model decisions against test cases to confirm that its behavior remains reliable.

Incident triage is incorrect. Incident triage deals with prioritizing and categorizing live alerts or cases as they occur. It does not involve systematic testing of the model with predefined examples to confirm that it is still detecting threats and ignoring harmless activity correctly.

Related Content



4.1.5 The Human Role in AI Security

resources\questions\q_the_human_role_in_ai_security_04.question.xml

Which tool is specifically used to analyze datasets and models for vulnerabilities such as poisoned samples or crafted inputs intended to mislead an AI system?

- ☐ Synthetic Data Generator Suite
- ☐ Secure Shell Toolkit
- ☒ Adversarial Robustness Toolbox ✓ Correct
- ☐ OpenTelemetry

Explanation

Adversarial Robustness Toolbox is the correct answer. Adversarial Robustness Toolbox is a specialized framework used to evaluate and improve the resilience of AI models and datasets against adversarial attacks. It helps identify outliers, crafted inputs, and poisoned samples that could undermine an AI system's reliability and integrity.

OpenTelemetry is incorrect. OpenTelemetry focuses on observability by collecting metrics, logs, and traces from applications. While useful for monitoring performance and reliability, it is not designed to probe datasets or models for adversarial manipulations or poisoning attempts.

Secure Shell Toolkit is incorrect. A Secure Shell Toolkit is associated with managing secure remote access and command execution over encrypted channels. It protects administrative sessions but does not provide capabilities for adversarial testing of machine learning datasets or models.

Synthetic Data Generator Suite is incorrect. A synthetic data generator suite is aimed at creating artificial datasets for testing or training, often to preserve privacy or augment limited data. It does not focus on detecting adversarial examples or poisoned records within existing datasets.

Related Content

 1.3.2 Data Security Considerations for AI

 4.1.3 Data Security Considerations

resources\questions\q_data_security_considerations_05.question.xml

A company designs an AI-driven assistant for its finance department. The assistant can draft emails, summarize invoices, and propose budget adjustments.

However, it is also configured to approve wire transfers and modify vendor bank details directly in the payment system without requiring a human to confirm these changes.

What risk does this configuration primarily represent?

☒ Excessive agency ✔ Correct

☐ Model skewing

☐ AI supply chain attack

☐ Prompt injection

Explanation

Excessive agency is the correct answer. Excessive agency occurs when an AI system is given more autonomy and tool access than its role requires, especially for high-impact actions. Allowing the assistant to approve wire transfers and change bank details without human review gives it broad, risky control that can turn any error or compromise into a serious incident.

Prompt injection is incorrect. Prompt injection is about manipulating inputs so the model ignores its original instructions or behaves unexpectedly; the deeper problem here is that the system already lets the assistant execute sensitive actions without checks.

Model skewing is incorrect. Model skewing concerns shifts between training and production data distributions that change model behavior, not the amount of direct authority granted over financial transactions.

AI supply chain attack is incorrect. An AI supply chain attack involves compromised models, datasets, or components obtained from external sources, whereas this scenario is dangerous even with a trustworthy model because of how much operational power it has been given.

Related Content



4.2.6 AI Attacks Analysis and Controls

resources\questions\q_ai_attacks_analysis_and_controls_08.question.xml

A security operations center uses an AI vision system to automatically triage security camera footage at building entrances. The system tags individuals who appear on a watchlist and forwards those clips to human guards for review.

Recently, several test intrusions using known watchlisted employees were not tagged by the system, even though their faces were clearly visible to observers.

A forensic review reveals that the test subjects wore specially printed patterns on their sunglasses that slightly distort how the camera captures their facial features. The distortions are barely noticeable to humans but consistently cause the model to misclassify them as unknown visitors.

Which change would BEST reduce the risk associated with this type of attack?

- ☐ Deploy a secondary anomaly-detection model that monitors recognition outputs over time and flags cases where individuals repeatedly pass through entrances without ever being matched against the watchlist, even when they resemble known profiles.
- ☒ Require the AI vision system to propose tags while a human guard must approve any watchlist match before it is recorded or used to trigger further actions. ✓ Correct
- ☐ Retrain the model with additional examples of adversarial patterns and implement adversarial training techniques so the system becomes more robust to small, targeted visual perturbations in inputs.
- ☐ Add a pre-processing step that normalizes and filters all incoming video frames for unusual patterns, lens reflections, and color anomalies before they are evaluated by the recognition model.

Explanation

Requiring the AI vision system to propose tags while a human guard must approve any watchlist match before it is recorded or used to trigger further actions is the correct answer. The attack relies on adversarial input that fools the model but not humans. Using the model only to propose tags and requiring human approval for watchlist matches directly limits the impact of manipulated inputs, while still benefiting from AI triage.

Retraining the model with additional examples of adversarial patterns and implement adversarial training techniques is incorrect. Adversarial training can help, but it cannot anticipate all future patterns and may still be bypassed. On its own, it does not provide a strong safety net when the model is used for high-risk access decisions.

Adding a pre-processing step that normalizes and filters all incoming video frames for unusual patterns, lens reflections, and color anomalies is incorrect. Pre-processing may clean up noise and some artifacts, but adversarial patterns are designed to survive typical filters. This improves image quality, not the fundamental reliance on a model that can still be fooled.

Deploying a secondary anomaly-detection model that monitors recognition outputs over time is incorrect. An anomaly-detection layer adds monitoring but reacts after multiple failures. For physical access control, this delayed response is weaker than putting human review directly in the decision flow for each potential watchlist match.

Related Content



4.2.1 Analyzing AI Attacks

resources\questions\q_analyzing_ai_attacks_11.question.xml

Which concept is most relevant when protecting the integrity of an AI model's intermediate reasoning steps so they cannot be tampered with or used to shift its behavior over time?

☒ Chain of thought ✓ Correct

☐ Output formatting

☐ Guardrail policies

☐ Rate limiting

Explanation

Chain of thought is the correct answer. Chain of thought is the model's intermediate reasoning, often stored or reused as context. If those steps are altered or injected with malicious text, the model's later behavior can be steered, so protecting them directly concerns securing the chain of thought.

Guardrail policies is incorrect. Guardrail policies define what the model is allowed to do, such as blocking unsafe topics. They influence behavior but are not the internal sequence of reasoning steps themselves.

Output formatting is incorrect. Output formatting controls how final answers are structured, like enforcing JSON or templates. It addresses the form of the response, not the underlying reasoning sequence.

Rate limiting is incorrect. Rate limiting restricts how many requests can be made over time. It mitigates abuse volume but does not protect or control the content of intermediate reasoning.

Related Content

resources\questions\q_analyzing_ai_attacks_07.question.xml

A financial services company deploys an AI system to flag potentially fraudulent transactions. Regulators request evidence showing how the organization ensures that the system's decisions are explainable and based on properly governed data.

The security architect needs to strengthen transparency around how training data and model decisions are managed.

Which approach BEST applies transparency principles in this context?

- ☐ Increase the model's detection sensitivity, shorten data retention for training logs, and have a single engineer approve all model updates for faster turnaround.
- ☐ Tune the analyst interface, add high-level summary dashboards, and send monthly executive reports on total alerts and blocked transactions across regions.
- ☐ Encrypt all training data at rest, restrict model access to a small specialist team, and disable detailed logging to reduce information leakage about internal behavior.
- ☒ Document data sources and cleansing rules, record model versions with evaluation metrics, and keep audit trails for major configuration and threshold changes. ✓ Correct

Explanation

Document data sources and cleansing rules, record model versions with evaluation metrics, and keep audit trails for major configuration and threshold changes is the correct answer. Documented data provenance, model versioning with metrics, and audited configuration changes make it clear how data is prepared, how models evolve, and why decisions change, directly supporting transparency.

Increase the model's detection sensitivity is incorrect. Adjusting sensitivity and retention affects operations, not clarity. A single approver with limited documentation reduces, rather than increases, visibility into how and why changes are made.

Encrypt all training data at rest is incorrect. Stronger confidentiality controls are useful, but disabling detailed logging removes the records needed to explain training history, configuration changes, and specific decisions.

Tune the analyst interface is incorrect. Dashboards and reports show outcomes, but without data lineage, model version history, and change documentation, stakeholders cannot see how those outcomes were produced.

Related Content



4.1.4 AI Life Cycle Security Considerations

resources\questions\q_ai_life_cycle_security_considerations_10.quesiton.question.xml

Which control most directly helps reduce the risk of model theft against a deployed AI API?

- ☒ Monitoring query patterns and throttling excessive or suspicious access from clients. ✓ Correct
- ☐ Publishing detailed chain-of-thought traces to help users understand every reasoning step.
- ☐ Maintaining a public catalog of model cards that describes training data and limitations.
- ☐ Allowing unrestricted batch downloads of model checkpoints for internal teams.

Explanation

Monitoring query patterns and throttling excessive or suspicious access from clients is the correct answer. Monitoring queries and throttling suspicious or high-volume access directly disrupts large-scale automated querying, which is a common method for cloning a model through its API.

Maintaining a public catalog of model cards that describes training data and limitations is incorrect. Model cards mainly support transparency and governance; they do not prevent an attacker from sending many queries or copying the model's behavior.

Allowing unrestricted batch downloads of model checkpoints for internal teams is incorrect. Unrestricted checkpoint downloads make model theft easier by giving attackers direct access to the model weights instead of forcing them to extract behavior through queries.

Publishing detailed chain-of-thought traces to help users understand every reasoning step is incorrect. Publishing detailed chain-of-thought traces can expose internal reasoning and patterns that help an attacker reverse-engineer or replicate the model, increasing theft risk.

Related Content



4.2.4 Model Inversion and Model Theft

resources\questions\q_model_inversion_and_model_theft_01.question.xml

Which defensive measure best helps an AI-driven network monitoring pipeline distinguish between a real lull in traffic and a disruption caused by an attack on collection endpoints?

- ☐ Increasing the batch size used for model inference during periods of low network activity.
- ☐ Randomly dropping a portion of incoming events to keep the pipeline from becoming overloaded.
- ☒ Exchanging cryptographically signed heartbeat messages with sequence numbers and expiry information. ✓ Correct
- ☐ Disabling redundant sensors to simplify the architecture and reduce noise in the data feed.

Explanation

Exchanging cryptographically signed heartbeat messages with sequence numbers and expiry information is the correct answer. Signed heartbeat messages with sequence numbers and expiry give the ingest layer a way to confirm that collectors are alive and sending data on time. If heartbeats stop or arrive out of order, the system can infer a collection problem or attack rather than assuming that traffic has simply gone quiet.

Increasing the batch size used for model inference during periods of low network activity is incorrect. Changing batch size affects performance but does not verify whether data is actually flowing. Larger batches during low activity would not reveal if collectors are under attack or silently failing, so this does not reliably distinguish real lulls from disruptions.

Randomly dropping a portion of incoming events to keep the pipeline from becoming overloaded is incorrect. Randomly dropping incoming events intentionally reduces visibility. While it might reduce load, it makes it harder to detect subtle disruptions or poisoning attempts, since missing data could be caused by the random policy instead of an adversary.

Disabling redundant sensors to simplify the architecture and reduce noise in the data feed is incorrect. Turning off redundant sensors removes an important resilience layer. Redundancy helps confirm whether gaps are localized or systemic; disabling it makes it more difficult to determine if a lull is genuine or caused by an attack on specific collection points.

Related Content

 4.1.4 AI Life Cycle Security Considerations

Question 9

✓ Correct

A security team wants to detect if training files for a model are modified in storage before each retraining cycle. They implement cryptographic checksums and digital signatures to verify that files match approved versions.

Which type of control are they primarily using?

☒ Data integrity controls ✓ Correct

☐ Model guardrails

☐ Access controls

☐ Output validation

Explanation

Data integrity controls is the correct answer. Using checksums and digital signatures to confirm that training files still match approved versions is a direct use of data integrity controls, which detect unauthorized or accidental modifications.

Access controls is incorrect. These determine who can read or modify the training files through authentication and authorization, but they do not themselves check whether the files have already been altered.

Output validation is incorrect. This focuses on checking model responses or structured outputs for correctness or policy compliance, not on verifying that stored training data remains unchanged.

Model guardrails is incorrect. These constrain model behavior and outputs during inference according to safety rules; they do not verify the integrity of training files in storage.

Related Content



4.2.7 Applying Compensating Controls

resources\questions\q_applying_compensating_controls_05.question.xml

During model development for a security analytics system, why is it important to consider model selection in addition to training quality?

- ☐ To avoid having to perform any dependency scanning on machine learning libraries.
- ☐ To ensure that once trained, the model will never require retraining or performance reviews, even if attack patterns evolve over time.
- ☒ To ensure the model aligns with governance needs such as speed, explainability, and auditability. ✓ Correct
- ☐ To guarantee the model can be deployed without any network segmentation or access control.

Explanation

To ensure the model aligns with governance needs such as speed, explainability, and auditability is the correct answer. Model choice affects how quickly it responds, how easily analysts can interpret its decisions, and how well its behavior can be reviewed for compliance and investigations, not just its raw accuracy.

To guarantee the model can be deployed without any network segmentation is incorrect. Model selection does not remove the need for infrastructure security. Network segmentation and access controls are required regardless of which model architecture is chosen.

To avoid having to perform any dependency scanning on machine learning libraries is incorrect. Dependency scanning is still necessary to detect vulnerable or malicious libraries. Even a well-chosen model relies on code that must be checked for supply-chain risks.

To ensure that once trained, the model will never require retraining or performance reviews is incorrect. Threats and data patterns change. Any model, regardless of how it was selected, needs periodic evaluation and retraining to stay effective and secure.

Related Content



1.3.2 Data Security Considerations for AI



4.1.3 Data Security Considerations

resources\questions\q_data_security_considerations_06.question.xml

